



SOC 2 Type 2 Report

NAVE

August 1, 2024 to October 31, 2024

A Type 2 Independent Service Auditor's Report on Controls Relevant to Security



AUDIT AND ATTESTATION BY

**PRESCIENT
ASSURANCE**



CPA

AICPA NOTICE:

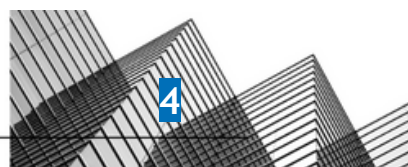
You may use the SOC for Service Organizations - Service Organizations Logo only for a period of twelve (12) months following the date of the SOC report issued by a licensed CPA. If after twelve months a new report is not issued, you must immediately cease use of the SOC for Service Organizations - Logo.

Table of Contents

Management's Assertion	5
INDEPENDENT SERVICE AUDITOR'S REPORT	8
Scope	8
Service Organization's Responsibilities	8
Service Auditors' Responsibilities	9
Inherent Limitations	9
Opinion	10
Restricted Use	10
SYSTEM DESCRIPTION	12
DC 1: Company overview and types of products and services provided	13
DC 2: The principal service commitments and system requirements	13
DC 3: The components of the system used to provide the services	14
3.1 Primary Infrastructure	14
3.2 People	15
3.3 Security Processes and Procedures	15
3.4 Third Party Access:	16
3.5 System Boundaries	16
DC 4: Disclosures about identified security incidents	16
DC 5: The applicable trust services criteria and the related controls designed to provide reasonable assurance that the service organization's service commitments and system requirements were achieved	17
5.1 Integrity and Ethical Values	17
5.2 Commitment to Competence	17
5.3 Management's Philosophy and Operating Style	17
5.5 Human Resource Policies and Practices	18
5.6 Security Management	18
5.7 Security and Privacy Policies	18
5.8 Personnel Security	19
5.9 Physical Security and Environmental Controls	19
5.10 Change Management	20
5.11 System Monitoring	20
5.12 Incident Management	20
5.13 Data Backup and Recovery	21
5.14 System Account Management	21
5.15 Data Classification	21
5.16 Risk Management Responsibilities	22



5.17 Risk Management Program Activities	22
5.18 Integration with Risk Assessment	23
5.19 Information and Communications Systems	23
5.20 Data Communication	23
5.21 Monitoring Controls	24
DC 6: Complementary User Entity Controls (CUECs)	24
DC 7: Complementary Subservice Organization Controls (CSOCs)	25
DC 8: Disclosures of out of scope Trust Services Criteria	26
DC 9: Disclosures of significant changes in last 1 year	26
TESTING MATRICES	27
Tests of Operating Effectiveness and Results of Tests	28
Scope of Testing	28
Types of Tests Generally Performed	28
General Sampling Methodology	29
Reliability of Information Provided by the Service Organization	29
Test Results	29



SECTION 1

Management's Assertion

nave



Management's Assertion

We have prepared the accompanying description of NAVE's system throughout the period August 1, 2024 to October 31, 2024, based on the criteria for a description of a service organization's system set forth in DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report. The description is intended to provide report users with information about NAVE's system that may be useful when assessing the risks arising from interactions with NAVE's system, particularly information about system controls that NAVE has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to Security set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*.

NAVE uses a subservice organization for cloud hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at NAVE, to achieve NAVE's service commitments and system requirements based on the applicable trust services criteria. The description presents NAVE's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of NAVE's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at NAVE, to achieve NAVE's service commitments and system requirements based on the applicable trust services criteria. The description presents NAVE's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of NAVE's controls.

We confirm, to the best of our knowledge and belief, that:

- a. The description presents NAVE's system that was designed and implemented throughout the period August 1, 2024 to October 31, 2024 in accordance with the description criteria.
- b. The controls stated in the description were suitably designed throughout the period August 1, 2024 to October 31, 2024, to provide reasonable assurance that NAVE's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout the period, and if the subservice organization and user entities applied the complementary controls assumed in the design of NAVE's controls during that period.
- c. The controls stated in the description operated effectively throughout the period August 1, 2024 to October 31, 2024, to provide reasonable assurance that NAVE's service commitments and system requirements were achieved based on the applicable trust services criteria, if the complementary subservice organization and complementary user entity controls assumed in the design of NAVE's controls operated effectively throughout the period.

DocuSigned by:

Sonya Siderova

DB4E47FF00974E1.....

Sonya Siderova

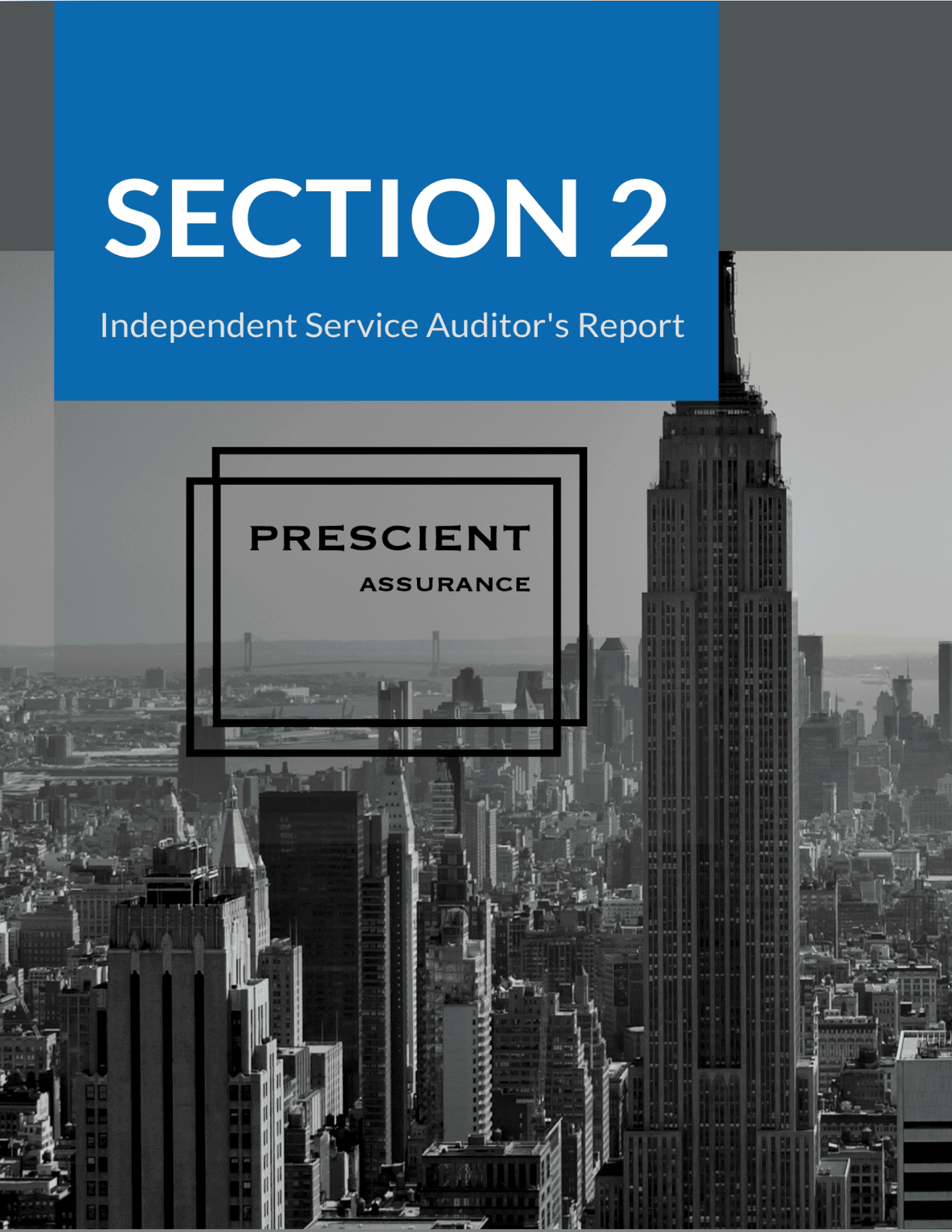
CEO

NAVE

SECTION 2

Independent Service Auditor's Report

PRESCIENT
ASSURANCE



INDEPENDENT SERVICE AUDITOR'S REPORT

To: NAVE

Scope

We have examined NAVE's ("NAVE") accompanying description of its Nave system found in Section 3, titled NAVE System Description throughout the period August 1, 2024 to October 31, 2024, based on the criteria for a description of a service organization's system set forth in DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report, and the suitability of the design and operating effectiveness of controls stated in the description throughout the period August 1, 2024 to October 31, 2024, to provide reasonable assurance that NAVE's service commitments and system requirements were achieved based on the trust services criteria relevant to Security set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*.

NAVE uses a subservice organization for cloud hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at NAVE, to achieve its service commitments and system requirements based on the applicable trust services criteria. The description presents NAVE's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of NAVE's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that certain complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at NAVE, to achieve NAVE's service commitments and system requirements based on the applicable trust services criteria. The description presents NAVE's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of NAVE's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

Service Organization's Responsibilities

NAVE is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that NAVE's service commitments and system requirements were achieved. In Section 1, NAVE has provided the accompanying assertion titled "Management's Assertion of NAVE" (assertion) about the description and the suitability of the design and operating effectiveness of controls stated therein. NAVE is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditors' Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the AICPA. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operating effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of the description of a service organization's system and the suitability of the design and operating effectiveness of controls involves:

1. Obtaining an understanding of the system and the service organization's service commitments and system requirements.
2. Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
3. Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
4. Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
5. Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
6. Evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service

organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Opinion

In our opinion, in all material respects:

- a. The description presents NAVE's system that was designed and implemented throughout the period August 1, 2024 to October 31, 2024, in accordance with the description criteria.
- b. The controls stated in the description were suitably designed throughout the period August 1, 2024 to October 31, 2024, to provide reasonable assurance that NAVE's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout the period and if the subservice organization and user entities applied the complementary controls assumed in the design of NAVE's controls throughout the period.
- c. The controls stated in the description operated effectively throughout the period August 1, 2024 to October 31, 2024, to provide reasonable assurance that NAVE's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls assumed in the design of NAVE's controls operated effectively throughout the period.

Restricted Use

This report is intended solely for the information and use of NAVE, user entities of NAVE's system during some or all of the period August 1, 2024 to October 31, 2024, business partners of NAVE subject to risks arising from interactions with the system, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

1. The nature of the service provided by the service organization.
2. How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties.
3. Internal control and its limitations.
4. Complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.
5. User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.
6. The applicable trust services criteria.

7. The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

Signed by:
Prescient Assurance
-----3E24GA8A45DE434-----

Prescient Assurance LLC
February 6, 2025

SECTION 3

System Description

nave

DC 1: Company overview and types of products and services provided

Nave ("we," "our," "us", "the Company"), with its headquarters in Bulgaria, is a forward-thinking technology company focused on enhancing the efficiency of agile teams. Founded by an expert with rich backgrounds in agile practices, data science, and software development, our aim is simple: to transform project management by making it more data-driven and efficient. Our team's combined experience has equipped us with unique insights into the challenges of product development, inspiring us to create Nave—a platform designed to streamline the agile process through sophisticated analytics and user-friendly dashboards.

We believe that the essence of improving product development and team productivity lies in a thorough analysis of workflow data. Nave introduces an innovative approach to project management for agile teams, offering a suite of analytical tools that shed light on performance metrics, workflow bottlenecks, and efficiency opportunities. Our service is not just another tool but a comprehensive solution that turns data into actionable insights, empowering teams to make informed decisions and achieve optimal results.

Our platform stands out by seamlessly integrating with popular project management tools such as Jira, Trello, Azure DevOps, Asana, and others. This compatibility ensures that teams can adopt Nave without disrupting their existing workflows while benefiting from enhanced visibility and control over their projects. By leveraging advanced data analytics, including machine learning, Nave enables teams to adopt a more objective and measurable approach to project management. Our goal is to facilitate a shift from intuition-based decisions to a data-driven strategy, improving project outcomes and accelerating development cycles.

DC 2: The principal service commitments and system requirements

Nave designs its processes and procedures to meet the objectives of improving financial performance and managing risk (customer outcome). Those objectives are based on the service commitments that Nave makes to user entities, the laws and regulations that govern the provision of services, and the financial, operational, and compliance requirements that Nave has established for the services. The services of Nave are subject to the privacy and security laws and regulations in the jurisdictions in which Nave operates.

Security commitments are standardized and include, but are not limited to, the following:

- Security principles within the fundamental designs of the Nave platform that are designed to permit system users to access the information they need based on their role in the system while restricting them from accessing information not needed for their role.
- Maintain commercially reasonable administrative, technical, and organizational measures that are designed to protect customer data processed.
- Encryption of data at rest and in transit.
- Maintain security procedures that are consistent with applicable industry standards.
- Document and enforce confidentiality agreements with third parties prior to sharing confidential data.

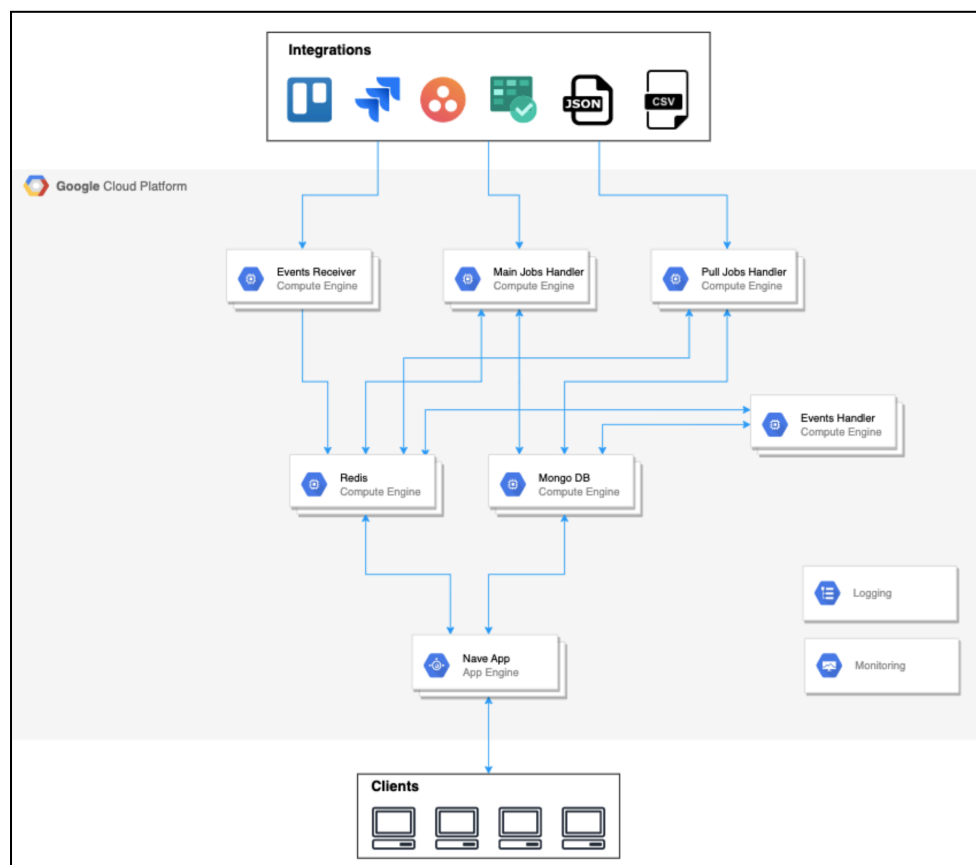
- Review documentation from third-party providers to help ensure that they comply with security and confidentiality policies.
- Maintain business continuity and disaster recovery programs.
- Restrict system access to authorized personnel only.
- Regularly assess security programs and processes.
- Identification and remediation of security incidents/events.

Nave establishes systems and operational requirements that support the achievement of service commitments, relevant laws and regulations, and other security and privacy requirements. Such requirements are communicated in Nave's Terms and Conditions (<https://getnave.com/terms-services>). Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed and how employees are hired and trained. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the operation and development of the Nave platform.

DC 3: The components of the system used to provide the services

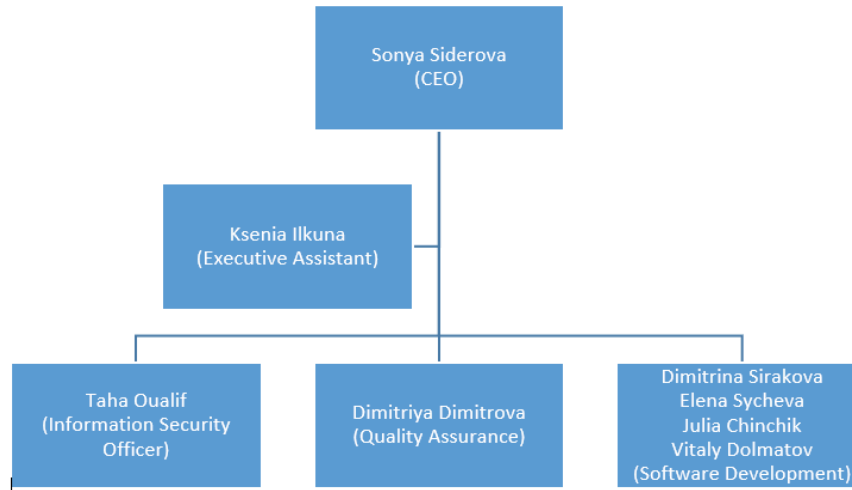
3.1 Primary Infrastructure

The following diagram shows the primary infrastructure of the Nave application.



3.2 People

The organizational chart is the following:



3.3 Security Processes and Procedures

The Company employs a set of procedures in order to obtain its objectives for network and data security. These procedures are executed by qualified and experienced team members. Procedures are in place in the following areas:

Nave's application runs in the Google Cloud Platform (GCP) utilizing Virtual Machines, Storage and Database services.

- The GCP infrastructure provides granular access control to all aspects of the infrastructure. Access from external locations is controlled through configuration and firewall rules. Access to internal components of the platform is only possible via MFA controlled access utilizing Secure Shell ("SSH") protocol.
- Data is persisted in GCP Storage and utilizes Advanced Encryption Standard ("AES") 256 encrypted disks for all data stored at rest.
- User entities access their instance using standard web browsers utilizing Transport Layer Security ("TLS") 1.2 or above for encrypted communications.
- Security Policy Administration: The Company's policies concerning various security, availability, processing integrity, confidentiality, and privacy matters are reviewed at least annually.
- Risk Assessment: At least annually the Chief Executive, Development, Security, and IT Teams collaborate on an overall risk assessment for the Company and the System.
- Communication: The Company opportunistically and continually uses a mixture of intranet services, email, and remote meeting opportunities for the communication of security policies and procedures.

- Logical Access: All team members must have unique credentials as well as established authorization to access the Company's information assets. Access to systems and information is restricted based on the responsibilities of the individual and their role.
- Change Management: The Company has a Software Development Lifecycle Policy. The policy covers the planning, assignment, development, design, code review, impact considerations, infrastructure assignments, quality assurance, security testing, implementation, and maintenance of both the System software and infrastructure.

3.4 Third Party Access:

Third-Party Summary	
Name	Purpose
GCP	Cloud hosting provider Infrastructure Vulnerability Management
Trello	Project management and issue tracking
Snyk	Source code vulnerability management
Drata	Compliance management platform
Atlassian Bitbucket	Source code repository
Google	File storage, email, document collaboration, Identity Provider
Jenkins	CI/CD
Skype for Business	Corporate messaging and collaboration

3.5 System Boundaries

The system in scope is the Nave application and its supporting infrastructure and processes.

DC 4: Disclosures about identified security incidents

No security incidents have occurred during the audit period.

DC 5: The applicable trust services criteria and the related controls designed to provide reasonable assurance that the service organization's service commitments and system requirements were achieved

5.1 Integrity and Ethical Values

Nave uses its Code of Conduct, which is read and signed by all employees as part of the onboarding process, to define and lay out our values. Nave has also instituted a number of technical controls to prevent and disincentive illegal and unethical actions by Nave employees. These controls include but are not limited to:

- Logging all traffic within Nave's environment by users for full traceability.
- Limiting access to confidential information based on clearly defined roles and following the principle of least privilege.
- Rigorously upholding the standards of ethical behavior laid out in our Code of Conduct, especially as they pertain to discrimination and harassment of any kind.
- Performing background checks on employees as part of the hiring process and as required by their role.
- Protecting and valuing individuals who bring concerns to the attention of Nave management.
- Use of NDAs to prevent the disclosure of confidential information to unauthorized parties.

5.2 Commitment to Competence

Nave's management defines competence as the knowledge and skills necessary to accomplish tasks that define employees' roles and responsibilities. Management's commitment to competence includes management's consideration of the competence levels for jobs and how those levels translate into the requisite skills and knowledge.

Specific control activities that have been implemented in this area are described below:

- Management has considered the competence levels for jobs and translated required skills and knowledge levels into written position requirements.
- Training is provided to maintain the skill level of personnel in certain positions.

5.3 Management's Philosophy and Operating Style

Nave's management team is committed to creating a productive and encouraging work environment as well as providing a secure product to our customers and users. To accomplish this Nave has instituted a number of processes:

- Regular meetings for employees to voice their blocks, successes, and concerns.
- A rigorous QA program ensuring that development on the Nave application meets industry security standards.
- Employees are encouraged to reach out to each other and to management when needed when facing obstacles.

5.4 Organizational Structure and Assignment of Authority and Responsibility

During normal operations Nave has a simple organizational structure. Employees report directly to the CEO, who ultimately provides direction. Nave has clearly defined job descriptions and as the organization grows, we have in place roles and responsibilities that will allow for the dissemination of managerial responsibilities as necessary. Nave has taken the following steps to achieve this goal:

- Regularly updated organization chart fully accessible by employees.
- Responsibilities of roles are clearly defined in policies and job descriptions.

5.5 Human Resource Policies and Practices

Nave consistently strives to hire and retain the most qualified individuals for the job. To meet this goal, Nave has in place onboarding requirements and a Human Resource Security Policy which covers employee security training, performance reviews, competency assessments, and the terms of employment.

Specifically, Nave has the following controls in place:

- Performance Reviews
- Annual employee security training
- New employees are required to sign a non-disclosure or confidentiality agreement.
- Clearly defined disciplinary process
- Lastly, Nave recognizes that policies and procedures often need to change to serve the needs of the organization. To accomplish this, all security procedures are reviewed at least annually.

5.6 Security Management

Nave uses an outsourced information security team consisting of a dedicated Information System Security Manager (ISSM) who is responsible for management of information security throughout the organization. The team maintains policies around the processing of security credentials, performs the technical onboarding/off-boarding work, and updates, maintains, and annually signs to acknowledge their review of the information security policies. They are responsible for enforcing the information security policies, configuring, monitoring and maintaining preventative, corrective, and detective controls within the Nave environment, and ensuring user awareness training is conducted.

As the information security team maintains security, it monitors known incidents and patches as well as results from recent vulnerability assessments and addresses necessary changes to the policies and procedures. Such changes can include a reclassification of data, a reassessment of risk, changes in incident response plans, and a verification of responsibilities for authorizing and monitoring access.

During annual security training and awareness programs, management ensures communication of the latest security policies.

Additionally, management is responsible for ensuring business associate agreements are current for third parties and for updating the annual IT risk assessment.

5.7 Security and Privacy Policies

Nave has adopted the following Security Policies:

- Acceptable Use Policy
- Asset Management Policy
- Backup Policy
- Breach Notification Policy
- Business Continuity Policy
- Code of Conduct
- Data Classification Policy
- Data Protection Policy
- Data Retention Policy
- Disaster Recovery Plan
- Encryption Policy
- Incident Response Plan
- Information Security Policy
- Password Policy
- Physical Security Policy
- Privacy Policy
- Risk Assessment Policy
- Software Development Life Cycle Policy
- System Access Control Policy
- Vendor Management Policy
- Vulnerability Management Policy

5.8 Personnel Security

Nave has several personnel security procedures in place specifically during the onboarding process. These include:

- Background checks for new employees.
- Employees must read and agree to all security policies.
- Roles within the organization have been clearly defined and are reflected in the organizational chart.
- Employees are granted access/authorization based on their role and in accordance with the principle of least privilege.
- Employees are required to sign an NDA.
- Security awareness training is completed by all employees in the first 30 days after they are hired.
- Employees are directed to report any potential security incidents to management.
- Violations of Nave security policies have clearly defined repercussions.

5.9 Physical Security and Environmental Controls

Nave is a fully remote company with no centralized headquarters or physical network. Because of this, physical and environmental security procedures have been deemed unnecessary. There are specific considerations taken, however, regarding remote work and the security risks inherent specific to companies that are fully remote.

5.10 Change Management

Nave's change management procedures are detailed in the Change Management Policy. There are five requirements for all changes to the organization, business processes, and systems that affect information security in Nave's production environment. They are as follows:

- The change must include processes for planning and testing of changes, including remediation measures.
- Documented managerial approval and authorization before proceeding with changes that may have a significant impact on information security, operations, or the production platform.
- Advance communication/warning of changes, including schedules and a description of reasonably anticipated effects, provided to all relevant internal and external stakeholders.
- Documentation of all emergency changes and subsequent review.
- A rollback process for unsuccessful deployments must be in place.

5.11 System Monitoring

Nave uses the GCP-provided monitoring features to monitor its network and systems, including but not limited to:

- CPU Usage alert
- GAE APP Error Count
- Memory consumption alert
- MongoDB Disk Space
- SSL certificate expiration
- Services Uptime check
- VM CPU
- VM Errors
- VM RAM
- VM SSD

Nave is constantly striving to improve our security monitoring capabilities and uses GCP's documentation on best practices to inform the alarming and logging measures we take.

5.12 Incident Management

Nave's incident response procedures are detailed in its Incident Response Plan. Our primary goals will be to investigate, contain any exploitations, eradicate any threats, recover Nave's systems, and remediate any vulnerabilities. Throughout this process, thorough documentation will be required as well as a post-mortem report.

Specific steps that Nave will take are:

- The Security Officer will manage the incident response effort.
- A recurring Incident Response Meeting will be held at regular intervals until the incident is resolved.
- Nave will inform all necessary parties of the incident without undue delay.

5.13 Data Backup and Recovery

Nave uses a fully automated backup schedule on GCP to ensure full backup recovery of its database. Access to Nave databases is heavily restricted using role-based authorization controls. Nave maintains multi-availability zone deployment for the continuation of business in case of primary database instance failover.

5.14 System Account Management

Nave's access management procedures are documented in its Access Control Policy. Nave uses Role-based authorization to control access to its network infrastructure. Nave uses the principle of least privilege to determine the type and level of access to grant users. A number of standards are in place which Nave uses when granting access to its systems:

- Technical access to Nave networks must be formally documented.
- Background checks will be performed on persons granted access to sensitive information.
- Only authorized Nave employees and third parties working off a signed contract or statement of work, with a business need, shall be granted access to the Nave production network.

With regards to access provisioning, Nave uses the following controls:

- Access is restricted to only what is necessary to perform job duties.
- No access may be granted earlier than the official employee start date, except to complete security awareness training.
- Access requests and rights modifications shall be documented in an access request ticket or email. No permissions shall be granted without approval from the system/data owner or management.
- Records of all permission and privilege changes shall be maintained for no less than one year.
- Sensitive access rights of users must be removed promptly within 24 hours of notification being given to the IT Manager.
- If current access rights are no longer needed due to transfer or change of role, termination of those rights must be performed promptly within 24 hours of notification being given to the IT Manager.

5.15 Data Classification

Nave has three classifications for the data it uses, processes, and produces. The classifications are:

- Confidential
- Restricted
- Public

Confidential data is considered highly sensitive and has heavy restrictions spelled out in Nave's Data Protection Policy. Examples include:

- PII
- Customer Data
- Nave financial and banking data
- Incident Reports
- Risk Assessment Reports
- Technical Vulnerability Reports

- Secret and Private Keys
- Source Code

Restricted data is defined as proprietary information requiring thorough protection. Access to this data is restricted to employees on a “need-to-know” basis. Approval is required for distribution. Examples include:

- Internal Policies
- Legal Documents
- Internal Reports
- Skype Messages
- Emails
- Contracts
- Bug Reports and Maintenance

Public data is defined as: Documents intended for public consumption, which can be freely distributed outside of Nave. Examples include:

- Marketing Materials
- Product Descriptions
- Release Notes
- External Facing Policies

5.16 Risk Management Responsibilities

Nave's Risk Management Policy details the primary responsibilities. Some or all of these roles can be held by a single individual.

Role	Responsibility
CEO	Ultimately responsible party for the acceptance and/or treatment of any risks to the organization.
CTO	Can approve the avoidance, remediation, transference, or acceptance of any risk cited in the Risk Register. This person shall be responsible for communicating risks to top management and the board and adopting risk treatments in accordance with executive direction.
IT Manager	Shall be responsible for adherence to the Risk Management Policy.

5.17 Risk Management Program Activities

On a practical level, Nave's Risk Management process involves 3 stages:

- Identification of risks,
- Assessment of their potential impact, and
- Risk treatment towards the risk.

Identification of risks involves categorization and investigation. Examples of categories used are

- Technical,
- Reputational,
- Contractual,
- Financial,
- Regulatory, and
- Fraud risks.

Nave's Business Continuity and Disaster Recovery Plan details our key business processes and critical services.

5.18 Integration with Risk Assessment

Nave's Risk Assessment process takes into account a number of factors each of which contributes to both the likelihood and potential impact of a given risk. These include:

- The criticality of potentially impacted business processes as laid out in the Business Continuity and Disaster Recovery Policy.
- Whether a risk could potentially impact the confidentiality, availability, integrity, or privacy of customer data or PII.
- Potential monetary loss.
- The ability of the risk to impact Nave's business objectives.
- Potential impact to Nave customers or vendors

Nave uses Risk Treatment Plans for any response to risks other than "Accept."

Nave is committed to handling and remediating risks inherent in any commitments, agreements, or responsibilities it may enter into or take on during the operation of the company. Nave takes into account all relevant factors; contractual, legal, and regulatory when designing these controls. Nave's CEO has the final say on the design and implementation of these controls.

In general, Nave's Risk Assessment procedure is still applicable to risks inherent in Nave's commitments and contractual responsibilities and should be applied to determining the severity of risks.

5.19 Information and Communications Systems

Nave uses Skype for Business for restricted internal communications. Nave also uses video conferencing tools and a company Gmail for both internal and external communications.

For workflow, project management, and sharing of internal documents, Nave uses Trello as well as a company Google Drive.

5.20 Data Communication

Nave uses HTTPS to communicate with and access its network. All traffic within the network is redirected from HTTP to HTTPS.

Access Control to the production code base is limited via the following controls:

- The production code branch is protected, requiring a merge request and approval before any changes can be made. This also protects the branch from being deleted.
- RBAC approach is used for accessing the application code repository.

- All accounts are under direct Nave oversight and control management.

5.21 Monitoring Controls

Nave takes a dual approach to continuous monitoring using both internal monitoring and relying on third parties.

Internal Monitoring:

Nave has a highly interconnected business process allowing for visibility and insight by management into the operations of each department. Corrective action is initiated through direct conference calls. Within departments, code reviews and Nave's continuous reviews ensure internal controls are being followed and implemented.

Third Party Monitoring:

Nave contracts a third party to perform annual penetration tests and reviews the security posture of all its high-risk vendors at least on an annual basis.

DC 6: Complementary User Entity Controls (CUECs)

Nave's services are designed with the assumption that user entities will implement certain controls. Such controls are called complementary user entity controls. It is not feasible for all the Trust Services Criteria related to Nave's services to be solely achieved by Nave's control procedures. Accordingly, user entities, in conjunction with the services, should establish their own internal controls or procedures to complement those of Nave.

The following complementary user entity controls should be implemented by user entities to provide additional assurance that the Trust Services Criteria described within this report are met. As these items represent only a part of the control considerations that might be pertinent at the user entities' locations, user entities' auditors should exercise judgment in selecting and reviewing these complementary user entity controls.

Trust Services Criteria	Complementary User Entity Controls
CC2.1	User entities are responsible for the security and integrity of data housed under user entity control, particularly the data utilized by Nave systems and services.
CC6.2	Determination of personnel who need specific functionality and the granting of such functionality is the responsibility of authorized personnel at the user entity. This includes allowing access to Nave's application keys and API keys for access to the web service API
CC6.3	Authorized users and their associated access are reviewed periodically

CC6.6	User entities will ensure protective measures are in place for their data as it traverses from user entity to Nave.
CC6.6	User entities should establish adequate physical security and environmental controls of all devices and access points residing at their operational facilities, including remote employees or at-home agents for which the user entity allows connectivity in order to provide authorized information to Nave.

DC 7: Complementary Subservice Organization Controls (CSOCs)

Although the subservice organization has been “carved out” for the purposes of this report, certain Trust Services Criteria are intended to be met by controls at the subservice organization. Complementary Subservice Organization Controls (CSOCs) are expected to be in place at GCP related to physical security and environmental protection, as well as backup, recovery, and redundancy controls related to availability. GCP physical security controls mitigate the risk of fires, power loss, climate, and temperature variabilities. Management of Nave receives and reviews the GCP SOC 2 report annually. In addition, through its operational activities, Nave management monitors the services performed by GCP to determine whether operations and controls expected to be implemented at the subservice organization are functioning effectively. Management also has communication with the subservice organization to monitor compliance with the service agreement, stay abreast of changes planned at the hosting facility, and relay any issues or concerns to GCP management.

It is not feasible for the criteria related to the System to be achieved solely by Nave. Therefore, each user entity's internal control must be evaluated in conjunction with Nave's controls and related tests, and results described in Section 4 of this report, considering the related CSOCs expected to be implemented at the subservice organization as described below.

Criteria	Complementary Subservice Organization Controls
CC6.4	GCP is responsible for restricting data center access to authorized personnel.
CC6.4	GCP is responsible for the 24/7 monitoring of data centers by closed circuit cameras and security personnel.
CC7.2	GCP is responsible for the installation of fire suppression and detection, and environmental monitoring systems at the data centers.
CC7.2	GCP is responsible for protecting data centers against disruption in power supply to the processing environment by an uninterruptible power supply.

CC7.2

GCP is responsible for overseeing the regular maintenance of environmental protections at data centers.

DC 8: Disclosures of out of scope Trust Services Criteria

There are no trust services criteria that are not relevant to the system in scope.

DC 9: Disclosures of significant changes in last 1 year

There were no changes during the audit period.

SECTION 4

Testing Matrices

PRESCIENT
ASSURANCE

Tests of Operating Effectiveness and Results of Tests

Scope of Testing

This report on the controls relates to Nave provided by NAVE. The scope of the testing was restricted to Nave, and its boundaries as defined in Section 3.

Prescient Assurance LLC conducted the examination testing throughout the period August 1, 2024 to October 31, 2024.

The tests applied to test the Operating Effectiveness of controls are listed alongside each of the respective control activities within the Testing Matrices. Such tests were considered necessary to evaluate whether the controls were sufficient to provide reasonable, but not absolute, assurance that all applicable trust services criteria were achieved during the review date. In selecting the tests of controls, Prescient Assurance LLC considered various factors including, but not limited to, the following:

- The nature of the control and the frequency with which it operates.
- The control risk mitigated by the control.
- The effectiveness of entity-level controls, especially controls that monitor other controls.
- The degree to which the control relies on the effectiveness of other controls.
- Whether the control is manually performed or automated.

Types of Tests Generally Performed

The table below describes the nature of our audit procedures and tests performed to evaluate the operational effectiveness of the controls detailed in the matrices that follow:

Test Types	Description of Tests
Inquiry	Inquired of relevant personnel with the requisite knowledge and experience regarding the performance and application of the related control activity. This included in-person interviews, telephone calls, e-mails, web-based conferences, or a combination of the preceding.
Inspection	Inspected documents and records indicating performance of the control. This includes, but is not limited to, the following: • Examination / Inspection of source documentation and authorizations to verify transactions processed. • Examination / Inspection of documents or records for evidence of performance, such as existence of initials or signatures. • Examination / Inspection of systems documentation, configurations, and settings; and • Examination / Inspection of procedural documentation such as operations manuals, flow charts and job descriptions.

General Sampling Methodology

Consistent with American Institute of Certified Public Accountants (AICPA) authoritative literature, Prescient Assurance utilizes professional judgment to consider the tolerable deviation rate, the expected deviation rate, the audit risk, the characteristics of the population, and other factors, to determine the number of items to be selected in a sample for a particular test. Prescient Assurance, in accordance with AICPA authoritative literature, selected samples in such a way that the samples were expected to be representative of the population. This included judgmental selection methods, where applicable, to ensure representative samples were obtained.

System-generated population listings were obtained whenever possible to ensure completeness prior to selecting samples. In some instances, full populations were tested in cases including but not limited to, the uniqueness of the event or low overall population size.

Reliability of Information Provided by the Service Organization

Observation and inspection procedures were performed related to certain system-generated reports, listings, and queries to assess the accuracy and completeness (reliability) of the information used in the performance of our testing of the controls.

Test Results

The results of each test applied are listed alongside each respective test applied within the Testing Matrices. Test results not deemed as control deviations are noted by the phrase "No exceptions noted." in the test result column of the Testing Matrices. Any phrase other than this constitutes either a test result that is the result of non-occurrence, a change in the application of the control activity, or a deficiency in the Operating Effectiveness of the control activity. Testing deviations identified within the Testing Matrices are not necessarily weaknesses in the total system of controls, as this determination can only be made after consideration of controls in place at user entities and subservice organizations, if applicable, and other factors.

Trust ID	COSO Principle	Control Description	Test Applied by the Service Auditor	Test Results
CC1.1	The entity demonstrates a commitment to integrity and ethical values.	Nave has policies and procedures in place to establish acceptable use of information assets approved by management, posted on the company wiki, and accessible to all employees. All employees must acknowledge the Acceptable Use Policy upon hire.	Inspected the Acceptable Use Policy to determine that the company has defined the authorized and acceptable uses of company devices and technology and requires personnel to accept and comply with its terms. Inspected the personnel policy acceptance data and policy center on the compliance platform to determine that no employee has been hired during the audit period	No exceptions noted.
CC1.1	The entity demonstrates a commitment to integrity and ethical values.	Company policies are accessible to all employees and, as appropriate, third parties. Personnel are required to acknowledge the information security policy and other topic-specific policies based on their job duties during onboarding and annually thereafter.	Inspected the policy list on Drata to determine that the policies are approved and accessible to employees and contractors via Drata. Inspected the policy acceptance data to determine that relevant current employees and contractors have accepted the information security policies.	No exceptions noted.
CC1.1	The entity demonstrates a commitment to integrity and ethical values.	Nave has established a Data Protection Policy and requires all employees to acknowledge it upon hire. Management monitors employees' acceptance of the policy.	Inspected the Data Protection Policy to determine that the company has defined the data handling, protection, and encryption requirements and requires all employees to comply with the policy. Inspected the personnel directory to determine that no employee was hired during the audit period.	Not tested. No employees hired during the audit period.
CC1.1	The entity demonstrates a commitment to integrity and ethical values.	Nave requires its contractors to read and acknowledge the Code of Conduct, read and acknowledge the Acceptable Use Policy, and pass a background check.	Inspected the personnel directory on Drata to determine that no contractors were hired during the audit period.	Not tested. No contractors hired during the audit period.
CC1.1	The entity demonstrates a commitment to integrity and ethical values.	Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	Inspected the personnel directory and policy center on Drata to determine that Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	No exceptions noted.
CC1.2	The board of directors demonstrates independence	Nave has an assigned security team that is responsible for the design, implementation, management, and review of the	Inspected the key personnel information to determine that the company has established a security committee that is responsible for	No exceptions noted.

	from management and exercises oversight of the development and performance of internal control.	organization's security policies, standards, baselines, procedures, and guidelines.	managing the security policies, standards, and guidelines.	
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Management reviews and approves company policies at least annually. Updates to the policies are made as deemed necessary based on changes to business objectives or risks to the environment.	Inspected the company's policies and their approval date on Drata to determine that the company reviews and approves company policies at least annually. Updates to the policies are made as deemed necessary based on changes to business objectives or risks to the environment.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Management has established and documented roles and responsibilities for information security for personnel, including responsibilities for implementation of the information security program and oversight activities.	Inspected the Information Security Policy to determine that the company has assigned the responsibility of managing the information security policies to the Security Officer.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	The company's board of directors or a relevant subcommittee is briefed by senior management at least annually on the state of the company's cybersecurity and privacy risk. The board or relevant subcommittee provides feedback and direction to management as needed.	Inspected the subcommittee meeting minutes to determine that the company's board of directors or a relevant subcommittee is briefed by senior management at least annually on the state of the company's cybersecurity and privacy risk. The board or relevant subcommittee provides feedback and direction to management as needed.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and	The company's board of directors or a relevant subcommittee meets at least annually to discuss company performance, strategic objectives, compliance initiatives, and cybersecurity	Inspected risk committee meeting minutes to determine that the company's board of directors or a relevant subcommittee meets at least annually to discuss company performance, strategic objectives, compliance initiatives, and cybersecurity and privacy risk and mitigation strategies.	No exceptions noted.

	performance of internal control.	and privacy risk and mitigation strategies.		
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	The company's board members have sufficient expertise to oversee management's ability to design, implement and operate information security controls. The board engages third-party information security experts and consultants as needed.	Inspected the LinkedIn profile of the board member showing their experience, education, and skills to determine that the board members are qualified individuals with sufficient expertise to oversee management abilities. Inspected the penetration test report compiled by Florjan Llapi to determine that the board engages third-party information security experts and consultants as needed.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	The company's board of directors has a documented charter that outlines its oversight responsibilities for internal control.	Inspected the company's board charter showing the roles and responsibilities of Board to determine that the company's board of directors has a documented charter that outlines its oversight responsibilities for internal control.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.	Nave has an assigned security team that is responsible for the design, implementation, management, and review of the organization's security policies, standards, baselines, procedures, and guidelines.	Inspected the key personnel information to determine that the company has established a security committee that is responsible for managing the security policies, standards, and guidelines.	No exceptions noted.

CC1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.	Nave reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	Inspected the organizational structure to determine that the company reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	No exceptions noted.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Management evaluates candidates for employment through a formal interview process. The process may include verification of academic and professional qualifications, identity verifications, validation of references, technical interviews, or other steps as deemed applicable by the organization.	Inspected the personnel directory to determine that no employees were hired during the audit period.	Not tested. No employees hired during the audit period.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	Inspected the personnel directory and policy center on Drata to determine that Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	No exceptions noted.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	All Nave positions have a detailed job description that lists qualifications, such as requisite skills and experience, which candidates must meet in order to be hired by Nave.	Inspected Job Description of key roles to determine that all Nave positions have a detailed job description that lists qualifications, such as requisite skills and experience, which candidates must meet in order to be hired by Nave.	No exceptions noted.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Nave has established training programs to help employees understand their obligations and responsibilities for information security and privacy. Personnel (including employees and third parties as applicable) are required to complete the training during onboarding and annually thereafter.	Inspected the personnel compliance data to determine that the new hires have completed their security training and full-time employees have completed the training annually.	No exceptions noted.
CC1.4	The entity demonstrates a commitment to attract, develop,	Nave has a documented policy that outlines requirements for managing vendor and third party relationships.	Inspected the Vendor Management Policy to determine that the company has defined requirements including vendor risk assessment and review of the vendors to	No exceptions noted.

	and retain competent individuals in alignment with objectives.		ensure that third-party entities meet the organization's data preservation and protection requirements.	
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Nave requires its contractors to read and acknowledge the Code of Conduct, read and acknowledge the Acceptable Use Policy, and pass a background check.	Inspected the personnel directory on Drata to determine that no contractors were hired during the audit period.	Not tested. No contractors hired during the audit period.
CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Nave evaluates the performance of all employees through a formal, annual performance evaluation.	Inspected the performance evaluation reports for a sample of employees to determine that the company evaluates the performance of all employees through a formal, annual performance evaluation.	No exceptions noted.
CC1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	Nave has policies and procedures in place to establish acceptable use of information assets approved by management, posted on the company wiki, and accessible to all employees. All employees must acknowledge the Acceptable Use Policy upon hire.	Inspected the Acceptable Use Policy to determine that the company has defined the authorized and acceptable uses of company devices and technology and requires personnel to accept and comply with its terms. Inspected the personnel policy acceptance data and policy center on the compliance platform to determine that no employee has been hired during the audit period	No exceptions noted.
CC1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	Nave evaluates the performance of all employees through a formal, annual performance evaluation.	Inspected the performance evaluation reports for a sample of employees to determine that the company evaluates the performance of all employees through a formal, annual performance evaluation.	No exceptions noted.
CC1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	Inspected the personnel directory and policy center on Drata to determine that Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	No exceptions noted.
CC1.5	The entity holds individuals accountable for their internal	Nave has established training programs to help employees understand their obligations and responsibilities for	Inspected the personnel compliance data to determine that the new hires have completed their security training and	No exceptions noted.

	control responsibilities in the pursuit of objectives.	information security and privacy. Personnel (including employees and third parties as applicable) are required to complete the training during onboarding and annually thereafter.	full-time employees have completed the training annually.	
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave has defined and documented an Information Security Policy and other topic-specific policies as needed to support the functioning of internal control.	Inspected the Information Security Policy to determine that a detailed procedure is in place stating the requirements and responsibilities related to information security controls and compliance.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave authorizes access to information resources, including data and the systems that store or process sensitive data, based on the principle of least privilege.	Inspected User Access Permissions to determine that Nave authorizes access to information resources, including data and the systems that store or process sensitive data, based on the principle of least privilege.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave has an established policy and procedures that governs the use of cryptographic controls.	Inspected the Encryption Policy to determine that the company is required to implement authorized cryptographic controls and key management services to protect individual systems and information.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	A centralized asset register is maintained for physical, and information assets that includes business description, owner, and other attributes deemed relevant by the organization.	Inspected the asset inventory which includes asset classification, owners, and descriptions to determine that a centralized asset register is maintained for physical and other information assets that includes business description, owner, and other attributes deemed relevant by the organization.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave maintains an accurate architectural diagram to document system boundaries to support the functioning of internal control.	Inspected the company's architecture diagram to determine that the company has a formal diagram outlining its system boundaries.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave performs control self-assessments at least annually to gain assurance that controls are in place and operating effectively. Corrective actions are taken based on relevant findings.	Inspected the Drata monitoring dashboard and controls list to determine that the company uses Drata to perform control self-assessments continuously.	No exceptions noted.

	functioning of internal control.			
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave conducts continuous monitoring of security controls using Drata, and addresses issues in a timely manner.	Inspected the Drata compliance monitoring dashboard to determine that the company uses Drata to perform continuous monitoring of its security controls and to get issues addressed in a timely manner.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave Management has approved all policies that detail how customer data may be made accessible and should be handled. These policies are accessible to all employees and contractors.	Inspected the Acceptable Use Policy, Asset Management Policy, Data Protection Policy, Information Security Policy, and other policies to determine that relevant policies that detail how customer data may be accessed and handled have been approved by the management and are accessible to the employees and contractors through Drata.	No exceptions noted.
CC2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Nave has a defined policy that establishes requirements for the proper management and tracking of organizational assets.	Inspected the Asset Management Policy to determine that the company has outlined the procedures for properly managing its physical and digital assets according to the best practices and hardening standards.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	Inspected the personnel directory and policy center on Drata to determine that Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for	Nave conducts continuous monitoring of security controls using Drata, and addresses issues in a timely manner.	Inspected the Drata compliance monitoring dashboard to determine that the company uses Drata to perform continuous monitoring of its security controls and to get issues addressed in a timely manner.	No exceptions noted.

	internal control, necessary to support the functioning of internal control.			
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave provides a process to employees for reporting security, confidentiality, integrity, and availability features, incidents, and concerns, and other complaints to company management.	Inspected the Responsible Disclosure Policy to determine that an email address (security@getnave.com.) has been provided for users to submit a vulnerability report to the company's product security team.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Company policies are accessible to all employees and, as appropriate, third parties. Personnel are required to acknowledge the information security policy and other topic-specific policies based on their job duties during onboarding and annually thereafter.	Inspected the policy list on Drata to determine that the policies are approved and accessible to employees and contractors via Drata. Inspected the policy acceptance data to determine that relevant current employees and contractors have accepted the information security policies.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave has established a Data Protection Policy and requires all employees to acknowledge it upon hire. Management monitors employees' acceptance of the policy.	Inspected the Data Protection Policy to determine that the company has defined the data handling, protection, and encryption requirements and requires all employees to comply with the policy. Inspected the personnel directory to determine that no employee was hired during the audit period.	Not tested. No employees hired during the audit period.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.

CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	The security team communicates important information security events to company management in a timely manner.	Inspected Incident Log to determine that no incidents took place during the audit period.	Not tested. No incidents during the audit period.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC2.2	The entity internally communicates information, including objectives and	Nave has established training programs to help employees understand their obligations and responsibilities for information security and privacy. Personnel (including	Inspected the personnel compliance data to determine that the new hires have completed their security training and full-time employees have completed the training annually.	No exceptions noted.

	responsibilities for internal control, necessary to support the functioning of internal control.	employees and third parties as applicable) are required to complete the training during onboarding and annually thereafter.		
CC2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Nave has policies and procedures in place to establish acceptable use of information assets approved by management, posted on the company wiki, and accessible to all employees. All employees must acknowledge the Acceptable Use Policy upon hire.	Inspected the Acceptable Use Policy to determine that the company has defined the authorized and acceptable uses of company devices and technology and requires personnel to accept and comply with its terms. Inspected the personnel policy acceptance data and policy center on the compliance platform to determine that no employee has been hired during the audit period	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	Inspected Vendor Compliance Report to determine that Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave communicates system changes to customers that may affect security, availability, processing integrity, or confidentiality.	Inspected the release notes to determine that no system changes occurred during the audit period.	Not tested. No system changes during the audit period.
CC2.3	The entity communicates with external	Nave has a documented policy that outlines requirements for	Inspected the Vendor Management Policy to determine that the company has defined requirements including vendor risk	No exceptions noted.

	parties regarding matters affecting the functioning of internal control.	managing vendor and third party relationships.	assessment and review of the vendors to ensure that third-party entities meet the organization's data preservation and protection requirements.	
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave maintains a Terms of Service that is available to all external users and internal employees, and the terms detail the company's security and availability commitments regarding the systems. Client Agreements or Master Service Agreements are in place for when the Terms of Service may not apply.	Inspected the Terms Of Service on the company's website to determine that service, security, and confidentiality commitments are communicated to all external users and internal employees through the website.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave tracks security deficiencies through internal tools and closes them within an SLA that management has pre-specified.	Inspected event log to determine that no deficiencies were identified during the audit period.	Not tested. No deficiencies during the audit period.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave's security commitments are communicated to external users, as appropriate.	Inspected the Terms and Service and Privacy Policy to determine that the company communicates its commitments regarding security, privacy, and confidentiality.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons	No exceptions noted.

		evolved according to lessons learned and to incorporate industry developments.	learned and to incorporate industry developments.	
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave provides a communication feature or support portal to customers to report complaints, failures, bugs, incidents, vulnerabilities, requests for information, etc. Customer support tickets are responded by the support team within defined SLAs.	Inspected the Contact Us Page to determine that Nave provides a communication feature or support portal to customers to report complaints, failures, bugs, incidents, vulnerabilities, requests for information, etc. Inspected the customer support tickets log to determine that there were no complaints during the audit period.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave maintains a Privacy Policy that is available to all external users and internal employees, and it details the company's confidentiality and privacy commitments.	Inspected the Privacy Policy published on the company's website to determine that the company maintains a Privacy Policy that details the company's security and privacy commitments.	No exceptions noted.
CC2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	No exceptions noted.
CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.

CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave's Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.	Inspected a risk assessment report dated March 01, 2024, which includes a risk assessment approach, risk score matrix, results, and treatment plan to determine that a remediation plan is in place to formally manage the resolution of findings identified in risk assessment activities.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave has a documented policy that outlines requirements for managing vendor and third party relationships.	Inspected the Vendor Management Policy to determine that the company has defined requirements including vendor risk assessment and review of the vendors to ensure that third-party entities meet the organization's data preservation and protection requirements.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.

	and analyzes risks as a basis for determining how the risks should be managed.			
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	Inspected Vendor Compliance Report to determine that Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	No exceptions noted.
CC3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.
CC3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.	Nave's Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.	Inspected a risk assessment report dated March 01, 2024, which includes a risk assessment approach, risk score matrix, results, and treatment plan to determine that a remediation plan is in place to formally manage the resolution of findings identified in risk assessment activities.	No exceptions noted.
CC3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC3.4	The entity identifies and	Nave engages with third-party to conduct penetration tests of	Inspected the company's penetration test report conducted in November 2023, to	No exceptions noted.

	assesses changes that could significantly impact the system of internal control.	the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	Inspected the organizational structure to determine that the company reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	No exceptions noted.
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave has a documented policy that outlines requirements for managing vendor and third party relationships.	Inspected the Vendor Management Policy to determine that the company has defined requirements including vendor risk assessment and review of the vendors to ensure that third-party entities meet the organization's data preservation and protection requirements.	No exceptions noted.

CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave has a defined policy that establishes requirements for vulnerability management across the organization, including monitoring, cataloging, and assigning risk ratings to vulnerabilities to prioritize remediation efforts.	Inspected the Vulnerability Management Policy to determine that it describes the vulnerability tracking process, priority levels, and processes for closing the vulnerabilities.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function. The review includes validation of logical and physical access as necessary. Changes resulting from the review, if any, are documented and implemented.	Inspected User Access Review Report to determine that management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function.	No exceptions noted.

CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Nave has developed and documented a policy that outlines requirements for access control.	Inspected the System Access Control Policy to determine that guidelines and procedures for access control, reviews, unique user identification, and termination/offboarding have been documented.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.

	senior management and the board of directors, as appropriate.			
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document,	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to	No exceptions noted.

	deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	analyze, classify, and respond to incidents.	execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave's Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.	Inspected a risk assessment report dated March 01, 2024, which includes a risk assessment approach, risk score matrix, results, and treatment plan to determine that a remediation plan is in place to formally manage the resolution of findings identified in risk assessment activities.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.

	directors, as appropriate.	requirements prior to execution.		
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave has an assigned security team that is responsible for the design, implementation, management, and review of the organization's security policies, standards, baselines, procedures, and guidelines.	Inspected the key personnel information to determine that the company has established a security committee that is responsible for managing the security policies, standards, and guidelines.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of	Nave's Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.	Inspected a risk assessment report dated March 01, 2024, which includes a risk assessment approach, risk score matrix, results, and treatment plan to determine that a remediation plan is in place to formally manage the resolution of findings identified in risk assessment activities.	No exceptions noted.

	objectives to acceptable levels.			
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave has an assigned security team that is responsible for the design, implementation, management, and review of the organization's security policies, standards, baselines, procedures, and guidelines.	Inspected the key personnel information to determine that the company has established a security committee that is responsible for managing the security policies, standards, and guidelines.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	Inspected the organizational structure to determine that the company reviews its organizational structure, reporting lines, authorities, and responsibilities in terms of information security on an annual basis.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.

	objectives to acceptable levels.			
CC5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Nave conducts continuous monitoring of security controls using Drata, and addresses issues in a timely manner.	Inspected the Drata compliance monitoring dashboard to determine that the company uses Drata to perform continuous monitoring of its security controls and to get issues addressed in a timely manner.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave authorizes access to information resources, including data and the systems that store or process sensitive data, based on the principle of least privilege.	Inspected User Access Permissions to determine that Nave authorizes access to information resources, including data and the systems that store or process sensitive data, based on the principle of least privilege.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave has an assigned security team that is responsible for the design, implementation, management, and review of the organization's security policies, standards, baselines, procedures, and guidelines.	Inspected the key personnel information to determine that the company has established a security committee that is responsible for managing the security policies, standards, and guidelines.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave has an established policy and procedures that governs the use of cryptographic controls.	Inspected the Encryption Policy to determine that the company is required to implement authorized cryptographic controls and key management services to protect individual systems and information.	No exceptions noted.

CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave conducts a Risk Assessment at least annually.	Inspected the risk assessment report from March 2024 to determine that the company conducts a risk assessment at least annually.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Company policies are accessible to all employees and, as appropriate, third parties. Personnel are required to acknowledge the information security policy and other topic-specific policies based on their job duties during onboarding and annually thereafter.	Inspected the policy list on Drata to determine that the policies are approved and accessible to employees and contractors via Drata. Inspected the policy acceptance data to determine that relevant current employees and contractors have accepted the information security policies.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave Management has approved all policies that detail how customer data may be made accessible and should be handled. These policies are accessible to all employees and contractors.	Inspected the Acceptable Use Policy, Asset Management Policy, Data Protection Policy, Information Security Policy, and other policies to determine that relevant policies that detail how customer data may be accessed and handled have been approved by the management and are accessible to the employees and contractors through Drata.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave conducts continuous monitoring of security controls using Drata, and addresses issues in a timely manner.	Inspected the Drata compliance monitoring dashboard to determine that the company uses Drata to perform continuous monitoring of its security controls and to get issues addressed in a timely manner.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave has established training programs to help employees understand their obligations and responsibilities for information security and privacy. Personnel (including employees and third parties as applicable) are required to complete the training during onboarding and annually thereafter.	Inspected the personnel compliance data to determine that the new hires have completed their security training and full-time employees have completed the training annually.	No exceptions noted.
CC5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.	Nave's Management prepares a remediation plan to formally manage the resolution of findings identified in risk assessment activities.	Inspected a risk assessment report dated March 01, 2024, which includes a risk assessment approach, risk score matrix, results, and treatment plan to determine that a remediation plan is in place to formally manage the resolution of findings identified in risk assessment activities.	No exceptions noted.

CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	Inspected the personnel directory and policy center on Drata to determine that Nave has a formal Code of Conduct approved by management and accessible to all employees. All employees must acknowledge the Code of Conduct upon hire.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave has defined and documented an Information Security Policy and other topic-specific policies as needed to support the functioning of internal control.	Inspected the Information Security Policy to determine that a detailed procedure is in place stating the requirements and responsibilities related to information security controls and compliance.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Company policies are accessible to all employees and, as appropriate, third parties. Personnel are required to acknowledge the information security policy and other topic-specific policies based on their job duties during onboarding and annually thereafter.	Inspected the policy list on Drata to determine that the policies are approved and accessible to employees and contractors via Drata. Inspected the policy acceptance data to determine that relevant current employees and contractors have accepted the information security policies.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Management reviews and approves company policies at least annually. Updates to the policies are made as deemed necessary based on changes to business objectives or risks to the environment.	Inspected the company's policies and their approval date on Drata to determine that the company reviews and approves company policies at least annually. Updates to the policies are made as deemed necessary based on changes to business objectives or risks to the environment.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave conducts annual BCP/DR tests and documents according to the BCDR Plan.	Inspected the BCDR tabletop exercise meeting notes to determine that the company conducts annual BCP/DR tests and documents according to the BCDR Plan.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave has a defined Business Continuity Plan that outlines the proper procedures to respond, recover, resume, and	Inspected the company's Business Continuity Plan to determine that it outlines the proper procedures to respond, recover, resume, and restore operations following a disruption.	No exceptions noted.

	what is expected and in procedures that put policies into action.	restore operations following a disruption or significant change.		
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave provides a process to employees for reporting security, confidentiality, integrity, and availability features, incidents, and concerns, and other complaints to company management.	Inspected the Responsible Disclosure Policy to determine that an email address (security@getnave.com.) has been provided for users to submit a vulnerability report to the company's product security team.	No exceptions noted.
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Nave has an established Disaster Recovery Plan that outlines roles and responsibilities and detailed procedures for recovery of systems.	Inspected the Disaster Recovery Plan to determine that the disaster recovery procedures and roles and responsibilities of the CTO for damage assessment and implementation of recovery procedures have been defined.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Authentication requirements, such as single sign-on (SSO) authentication and/or strong password requirements, are enforced across all systems in accordance with company policy.	Inspected Account Credential configuration requirements to determine that authentication requirements, such as single sign-on (SSO) authentication and/or strong password requirements, are enforced across all systems in accordance with company policy.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Authentication to systems requires the use of multi-factor authentication.	Inspected the user listing and MFA configurations to determine that the company requires MFA to authenticate the users to systems.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets	A documented network diagram is in place to document system boundaries and connections to external networks. The diagram is reviewed and approved by management at least annually and updated as necessary when	Inspected the Network Diagram to determine that a documented network diagram is in place to document system boundaries and connections to external networks. The diagram is reviewed and approved by management at least annually and updated as necessary when there are changes to the environment.	No exceptions noted.

	to protect them from security events to meet the entity's objectives.	there are changes to the environment.		
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Administrative or privileged access to systems, resources, and data is restricted to authorized personnel.	Inspected the user access lists for GCP and Bitbucket to determine that the company has restricted admin access to authorized personnel only.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave ensures that a password manager is installed on all company-issued laptops.	Inspected the personnel compliance data to determine that relevant employees have a password manager installed on their company-issued devices.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Data at rest is encrypted using strong cryptographic algorithms.	Inspected that SQL databases, Redis installations, Memcache instances, and cloud storage buckets are encrypted at rest to determine that the company stores data at rest in encrypted form using strong cryptographic algorithms.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave has a defined policy that establishes requirements for the proper management and tracking of organizational assets.	Inspected the Asset Management Policy to determine that the company has outlined the procedures for properly managing its physical and digital assets according to the best practices and hardening standards.	No exceptions noted.

	events to meet the entity's objectives.			
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Username and password (password standard implemented) or SSO required to authenticate into application, MFA optional for external users, and MFA required for employee users.	Inspected the Username and Password configurations to determine that username and password (password standard implemented) or SSO required to authenticate into application, MFA optional for external users, and MFA required for employee users.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave has established a Data Protection Policy and requires all employees to acknowledge it upon hire. Management monitors employees' acceptance of the policy.	Inspected the Data Protection Policy to determine that the company has defined the data handling, protection, and encryption requirements and requires all employees to comply with the policy. Inspected the personnel directory to determine that no employee was hired during the audit period.	Not tested. No employees hired during the audit period.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave has documented baseline security configuration standards for all system components in accordance with industry-accepted system hardening standards or vendor hardening recommendations. These standards are updated as needed when vulnerabilities are identified and verified to be in place before or immediately after a system component is connected to a production environment.	Inspected the Asset Management Policy to determine that the company requires the hardening standards of device and infrastructure providers to be retained but default credentials to be changed, CIS benchmarks to be used where necessary, and 2FA, logging, patching, and malware protection to be implemented.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	Inspected the User Access Review Report to determine that access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	No exceptions noted.

	the entity's objectives.			
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Users can only access the production system remotely through the use of encrypted communication systems.	Inspected the remote access configurations to determine that the users can only access the production system remotely through encrypted communication systems.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave has an established key management process in place to support the organization's use of cryptographic techniques.	Inspected the Encryption Policy to determine that the company has defined a process for key management and requires keys to be managed using software that automatically manages the key generation, access control, secure storage, backup, and rotation of keys.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave has a defined policy that establishes requirements for the use of cryptographic controls.	Inspected the Encryption Policy to determine that the cryptographic controls, as well as the requirements for cryptographic keys, in order to protect the confidentiality, integrity, authenticity, and nonrepudiation of information is defined.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Unique user IDs are used for authentication to systems.	Inspected the unique account usage configurations to determine that employees have unique Google Cloud and Bitbucket accounts. Inspected the personnel data to determine that the employees have unique email IDs.	No exceptions noted.

CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Nave uses a version control system to manage source code, documentation, release labeling, and other change management tasks. Access to the system must be approved by a system admin.	Inspected the version control system configuration automated data to determine that the company has deployed Bitbucket as a version control system. Inspected the list of employees with access to Bitbucket to determine that no new access was granted during the audit period.	No exceptions noted.
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	A centralized asset register is maintained for physical, and information assets that includes business description, owner, and other attributes deemed relevant by the organization.	Inspected the asset inventory which includes asset classification, owners, and descriptions to determine that a centralized asset register is maintained for physical and other information assets that includes business description, owner, and other attributes deemed relevant by the organization.	No exceptions noted.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	Inspected the User Access Review Report to determine that access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	No exceptions noted.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is	External users must accept the Terms of Service prior to their account being created.	Inspected the sign-in page to determine that the company requires external users to accept the Terms of Service and Privacy Policy before creating their account.	No exceptions noted.

	administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function. The review includes validation of logical and physical access as necessary. Changes resulting from the review, if any, are documented and implemented.	Inspected User Access Review Report to determine that management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function.	No exceptions noted.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Nave uses a termination checklist to ensure that an employee's system access, including physical access, is removed within a specified timeframe and all organization assets (physical or electronic) are properly returned.	Inspected the Personnel Compliance Dashboard to determine that no access termination took place during the audit period.	Not tested. No terminations during the audit period.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes	Unique user IDs are used for authentication to systems.	Inspected the unique account usage configurations to determine that employees have unique Google Cloud and Bitbucket accounts.	No exceptions noted.

	new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.		Inspected the personnel data to determine that the employees have unique email IDs.	
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Nave has developed and documented a policy that outlines requirements for access control.	Inspected the System Access Control Policy to determine that guidelines and procedures for access control, reviews, unique user identification, and termination/offboarding have been documented.	No exceptions noted.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function. The review includes validation of logical and physical access as necessary. Changes resulting from the review, if any, are documented and implemented.	Inspected User Access Review Report to determine that management performs user access reviews periodically (as defined by policy and compliance requirements) to validate user accounts, including third party or vendor accounts, and their associated roles and permissions remain appropriate based on job function.	No exceptions noted.

CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	External users must accept the Terms of Service prior to their account being created.	Inspected the sign-in page to determine that the company requires external users to accept the Terms of Service and Privacy Policy before creating their account.	No exceptions noted.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Nave uses a termination checklist to ensure that an employee's system access, including physical access, is removed within a specified timeframe and all organization assets (physical or electronic) are properly returned.	Inspected the Personnel Compliance Dashboard to determine that no access termination took place during the audit period.	Not tested. No terminations during the audit period.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of	Nave has developed and documented a policy that outlines requirements for access control.	Inspected the System Access Control Policy to determine that guidelines and procedures for access control, reviews, unique user identification, and termination/offboarding have been documented.	No exceptions noted.

	least privilege and segregation of duties, to meet the entity's objectives.			
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Administrative or privileged access to systems, resources, and data is restricted to authorized personnel.	Inspected the user access lists for GCP and Bitbucket to determine that the company has restricted admin access to authorized personnel only.	No exceptions noted.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	Inspected the User Access Review Report to determine that access requests to information resources, including physical access and access to systems and data, are documented and approved by management based on least privilege, need to know, and segregation of duties principles.	No exceptions noted.
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Unique user IDs are used for authentication to systems.	Inspected the unique account usage configurations to determine that employees have unique Google Cloud and Bitbucket accounts. Inspected the personnel data to determine that the employees have unique email IDs.	No exceptions noted.

	responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.	Nave uses a termination checklist to ensure that an employee's system access, including physical access, is removed within a specified timeframe and all organization assets (physical or electronic) are properly returned.	Inspected the Personnel Compliance Dashboard to determine that no access termination took place during the audit period.	Not tested. No terminations during the audit period.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	A web application firewall is in place to protect public-facing web applications from outside threats.	Inspected the WAF configurations to determine that a web application firewall is in place to protect public-facing web applications from outside threats.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Network security controls are in place to limit inbound and outbound traffic to the environment to only what is necessary based on business justification. All other traffic is specifically denied.	Inspected the GCP firewall configuration test results to determine that configurations are in place to ensure only approved networking ports and protocols are implemented.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Username and password (password standard implemented) or SSO required to authenticate into application, MFA optional for external users, and MFA required for employee users.	Inspected the Username and Password configurations to determine that username and password (password standard implemented) or SSO required to authenticate into application, MFA optional for external users, and MFA required for employee users.	No exceptions noted.

CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Read/Write access to cloud data storage is configured to restrict public access.	Inspected the Drata automated test showing GCP Storage buckets marked as private to determine that existing GCP Storage buckets are private and public access to cloud data storage is restricted.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	No public SSH is allowed.	Inspected the Drata automated test showing public SSH is denied in GCP to determine that the company ensures that no public SSH is allowed.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Users can only access the production system remotely through the use of encrypted communication systems.	Inspected the remote access configurations to determine that the users can only access the production system remotely through encrypted communication systems.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Authentication requirements, such as single sign-on (SSO) authentication and/or strong password requirements, are enforced across all systems in accordance with company policy.	Inspected Account Credential configuration requirements to determine that authentication requirements, such as single sign-on (SSO) authentication and/or strong password requirements, are enforced across all systems in accordance with company policy.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	An intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	Inspected Alerting Configurations to determine that an intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its	Data in transit is encrypted using strong cryptographic algorithms.	Inspected the security certificate of the website valid till November 25, 2024, to determine that data in transit is encrypted using strong cryptographic algorithms.	No exceptions noted.

	system boundaries.			
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Nave's systems automatically log users out after a predefined period of inactivity and/or closure of the system or internet browser.	Inspected Session Configurations to determine that Nave's systems automatically log users out after a predefined period of inactivity and/or closure of the system or internet browser.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	A documented network diagram is in place to document system boundaries and connections to external networks. The diagram is reviewed and approved by management at least annually and updated as necessary when there are changes to the environment.	Inspected the Network Diagram to determine that a documented network diagram is in place to document system boundaries and connections to external networks. The diagram is reviewed and approved by management at least annually and updated as necessary when there are changes to the environment.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	SSH users use unique accounts to access production machines. Additionally, the use of the "Root" account is not allowed.	Inspected the SSH accounts user listing to determine that SSH users use unique accounts to access production machines. Additionally, the use of the Root account is not allowed.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Authentication to systems requires the use of multi-factor authentication.	Inspected the user listing and MFA configurations to determine that the company requires MFA to authenticate the users to systems.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Data in transit is encrypted using strong cryptographic algorithms.	Inspected the security certificate of the website valid till November 25, 2024, to determine that data in transit is encrypted using strong cryptographic algorithms.	No exceptions noted.

CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Nave uses encryption to protect user authentication and admin sessions of the internal admin tool transmitted over the Internet.	Inspected the security certificate of the company's website which is valid until November 25, 2024, to determine that user authentication and admin sessions of the internal admin tool transmitted over the internet are encrypted.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Data at rest is encrypted using strong cryptographic algorithms.	Inspected that SQL databases, Redis installations, Memcache instances, and cloud storage buckets are encrypted at rest to determine that the company stores data at rest in encrypted form using strong cryptographic algorithms.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	No public SSH is allowed.	Inspected the Drata automated test showing public SSH is denied in GCP to determine that the company ensures that no public SSH is allowed.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to	SSH users use unique accounts to access production machines. Additionally, the use of the "Root" account is not allowed.	Inspected the SSH accounts user listing to determine that SSH users use unique accounts to access production machines. Additionally, the use of the Root account is not allowed.	No exceptions noted.

	authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.			
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Nave has established a Data Protection Policy and requires all employees to acknowledge it upon hire. Management monitors employees' acceptance of the policy.	Inspected the Data Protection Policy to determine that the company has defined the data handling, protection, and encryption requirements and requires all employees to comply with the policy. Inspected the personnel directory to determine that no employee was hired during the audit period.	Not tested. No new hires during the audit period.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Nave has implemented segregation controls so that customers cannot impact or access data or resources of other customers.	Inspected the database segregation to determine that the company has implemented segregation controls so that customers cannot impact or access data or resources of other customers.	No exceptions noted.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Nave ensures that virtual machine OS patches are applied monthly.	Inspected the log of OS patches to determine that the company ensures that virtual machine OS patches are applied monthly.	No exceptions noted.

CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Antimalware software is installed on all company-managed devices.	Inspected the personnel compliance dashboard to determine that antivirus is enabled on the company's in-scope employee devices.	No exceptions noted.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to appropriate personnel and resolved, as necessary.	Inspected Logging and Monitoring configurations to determine that Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to appropriate personnel and resolved, as necessary.	No exceptions noted.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Nave's workstations operating system (OS) security patches are applied automatically.	Inspected the personnel compliance records showing that current employees have auto updates enabled to determine that operating system (OS) security patches are applied automatically.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Nave has a defined policy that establishes requirements for vulnerability management across the organization, including monitoring, cataloging, and assigning risk ratings to vulnerabilities to prioritize remediation efforts.	Inspected the Vulnerability Management Policy to determine that it describes the vulnerability tracking process, priority levels, and processes for closing the vulnerabilities.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and	Nave uses a version control system to manage source code, documentation, release labeling, and other change	Inspected the version control system configuration automated data to determine that the company has deployed Bitbucket as a version control system.	No exceptions noted.

	monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	management tasks. Access to the system must be approved by a system admin.	Inspected the list of employees with access to Bitbucket to determine that no new access was granted during the audit period.	
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Nave engages with third-party to conduct penetration tests of the production environment at least annually. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected the company's penetration test report conducted in November 2023, to determine that the company engages with third parties to conduct penetration tests at least annually. Moreover, no high-priority vulnerabilities were identified during the penetration test.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to appropriate personnel and resolved, as necessary.	Inspected Logging and Monitoring configurations to determine that Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to appropriate personnel and resolved, as necessary.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1)	Changes are peer-reviewed and approved prior to deployment by an individual different from the developer to maintain segregation of duties. Review requirements are enforced through automated mechanisms	Inspected a sample of pull requests to determine that changes are peer-reviewed and approved prior to deployment by an individual different from the developer to maintain segregation of duties. Review requirements are enforced through automated mechanisms such as branch	No exceptions noted.

	changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	such as branch protection settings in the production code repository.	protection settings in the production code repository.	
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Nave conducts continuous monitoring of security controls using Drata, and addresses issues in a timely manner.	Inspected the Drata compliance monitoring dashboard to determine that the company uses Drata to perform continuous monitoring of its security controls and to get issues addressed in a timely manner.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	An intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	Inspected Alerting Configurations to determine that an intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	No exceptions noted.
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.

	introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave has a defined policy that establishes requirements for vulnerability management across the organization, including monitoring, cataloging, and assigning risk ratings to vulnerabilities to prioritize remediation efforts.	Inspected the Vulnerability Management Policy to determine that it describes the vulnerability tracking process, priority levels, and processes for closing the vulnerabilities.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave uses logging software that sends alerts to appropriate personnel. Corrective actions are performed, as necessary, in a timely manner.	Inspected Logging and Monitoring configurations to determine that Nave uses logging software that sends alerts to appropriate personnel. Corrective actions are performed, as necessary, in a timely manner.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of	Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to	Inspected Logging and Monitoring configurations to determine that Nave has infrastructure logging configured to monitor web traffic and suspicious activity. When anomalous traffic activity is identified, alerts are automatically created, sent to	No exceptions noted.

	malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	appropriate personnel and resolved, as necessary.	appropriate personnel and resolved, as necessary.	
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave uses a system that collects and stores server logs in a central location. The system can be queried in an ad hoc fashion by authorized users.	Inspected the GoogleCloud log group records and users list to determine that the company utilizes a log management system that collects and stores server logs centrally and the system can be queried in an ad hoc fashion by authorized users.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave's cloud infrastructure is monitored through an operational audit system that sends alerts to appropriate personnel	Inspected the monitoring policies, notification channels, and list of alerts to determine that the company's cloud infrastructure is monitored through an operational audit system that sends alerts to appropriate personnel.	No exceptions noted.

CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	An intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	Inspected Alerting Configurations to determine that an intrusion detection system (IDS)/intrusion prevention system (IPS) or equivalent is in place to detect real-time suspicious or anomalous network traffic that may be indicative of threat actor activity and is configured to alert personnel when a potential intrusion is detected.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave is using Drata to monitor the security and compliance of its cloud infrastructure configuration	Inspected that GCP is linked to Drata to determine that the company uses Drata to monitor the security and compliance of its cloud infrastructure configuration.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are	Nave tracks and prioritizes security deficiencies through internal tools according to their severity by an independent technical resource.	Inspected event log to determine that no deficiencies were identified during the audit period.	Not tested. No deficiencies during the audit period.

	analyzed to determine whether they represent security events.			
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Results are reviewed by management and high priority findings are tracked to resolution.	Inspected Vulnerability Scan Report to determine that Nave engages with third-party to conduct vulnerability scans of the production environment at least quarterly. Inspected the Vulnerability Scan Report to determine that there were no high priority findings during the audit period.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions	The security team communicates important information security events to company management in a timely manner.	Inspected Incident Log to determine that no incidents took place during the audit period.	Not tested. No incidents during the audit period.

	to prevent or address such failures.			
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	No exceptions noted.
CC7.3	The entity evaluates security events to	Nave tracks and prioritizes security deficiencies through internal tools according to their	Inspected event log to determine that no deficiencies were identified during the audit period.	Not tested. No deficiencies

	determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	severity by an independent technical resource.		during the audit period.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC7.4	The entity responds to	Nave has a documented incident response plan that	Inspected the Incident Response Plan to determine that the company has defined the	No exceptions noted.

	identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Nave tracks and prioritizes security deficiencies through internal tools according to their severity by an independent technical resource.	Inspected event log to determine that no deficiencies were identified during the audit period.	Not tested. No deficiencies during the audit period.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Backups of production data are performed least daily and are retained per company policies and procedures.	Inspected the backup configurations to determine that the company performs backups daily and is retained per company policies and procedures.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave has a defined Business Continuity Plan that outlines the proper procedures to respond, recover, resume, and restore operations following a disruption or significant change.	Inspected the company's Business Continuity Plan to determine that it outlines the proper procedures to respond, recover, resume, and restore operations following a disruption.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave performs a test of all components of the incident response plan and procedures at least annually through different mechanisms including simulated events. The documented plan and procedures are updated if necessary based on the results of the test.	Inspected the Incident Response exercise from March 2024 to determine that the company tests its incident procedures at least annually using simulated events.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements	Nave tracks and prioritizes security deficiencies through internal tools according to their	Inspected event log to determine that no deficiencies were identified during the audit period.	Not tested. No deficiencies during the audit period.

	activities to recover from identified security incidents.	severity by an independent technical resource.		
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave has an established Disaster Recovery Plan that outlines roles and responsibilities and detailed procedures for recovery of systems.	Inspected the Disaster Recovery Plan to determine that the disaster recovery procedures and roles and responsibilities of the CTO for damage assessment and implementation of recovery procedures have been defined.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests,	Access to deploy changes to production is restricted to authorized personnel in accordance with segregation of duties principles.	Inspected the access list for Bitbucket to determine that the company has prepared a list of authorized users, who can merge changes to the main branch on Bitbucket.	No exceptions noted.

	approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Nave uses a version control system to manage source code, documentation, release labeling, and other change management tasks. Access to the system must be approved by a system admin.	Inspected the version control system configuration automated data to determine that the company has deployed Bitbucket as a version control system. Inspected the list of employees with access to Bitbucket to determine that no new access was granted during the audit period.	No exceptions noted.
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Changes are peer-reviewed and approved prior to deployment by an individual different from the developer to maintain segregation of duties. Review requirements are enforced through automated mechanisms such as branch protection settings in the production code repository.	Inspected a sample of pull requests to determine that changes are peer-reviewed and approved prior to deployment by an individual different from the developer to maintain segregation of duties. Review requirements are enforced through automated mechanisms such as branch protection settings in the production code repository.	No exceptions noted.
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Nave ensures that code changes are tested prior to deployment to ensure quality and security.	Inspected a sample of code changes to determine that code changes were tested before deployment and ascertained that the control was operating effectively.	No exceptions noted.
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Pre-production environments (e.g., development, testing, etc.) are separated from production environments and	Inspected the separate databases to determine that the company's Pre-production environments (e.g., development, testing, etc.) are separated from production	No exceptions noted.

	configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	the separation is enforced with access controls.	environments and the separation is enforced with access controls.	
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Nave has developed policies and procedures governing the system development life cycle, including documented policies for tracking, testing, approving, and validating changes.	Inspected the Software Development Life Cycle Policy to determine that the company has defined the software development phases and security control guidelines.	No exceptions noted.
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Change releases are approved by authorized personnel prior to deployment to production.	Inspected the production code changes to ensure that only authorized personnel, specifically employees and contractors, are permitted to alter the code and merge it into the default branch of the repository and the change releases are approved by authorized personnel prior to deployment to production.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Backups of production data are performed least daily and are retained per company policies and procedures.	Inspected the backup configurations to determine that the company performs backups daily and is retained per company policies and procedures.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave utilizes multiple availability zones to replicate production data across different zones.	Inspected the Drata automated test to determine that the company utilizes multiple availability zones on GCP to replicate production data across different zones.	No exceptions noted.

CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave has an established Disaster Recovery Plan that outlines roles and responsibilities and detailed procedures for recovery of systems.	Inspected the Disaster Recovery Plan to determine that the disaster recovery procedures and roles and responsibilities of the CTO for damage assessment and implementation of recovery procedures have been defined.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave has defined a formal risk management process that specifies risk tolerances and the process for evaluating risks based on identified threats and the specified tolerances.	Inspected the Risk Management Procedure to determine that the company has defined risk assessment processes and remediation strategies for identified risks based on their severity levels.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave evaluates security events to determine if they constitute an incident. Incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	Inspected Security Event Log to determine that Nave evaluates security events to determine that there are no incidents during the audit period. Inspected the Incident Response Plan to determine that incidents are assigned a priority, documented, tracked, and resolved in accordance with company policies and procedures.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave has a defined Business Continuity Plan that outlines the proper procedures to respond, recover, resume, and restore operations following a disruption or significant change.	Inspected the company's Business Continuity Plan to determine that it outlines the proper procedures to respond, recover, resume, and restore operations following a disruption.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave has a documented incident response plan that outlines roles, responsibilities, and procedures to document, analyze, classify, and respond to incidents.	Inspected the Incident Response Plan to determine that the company has defined the roles and responsibilities of the Information Security Manager and other key personnel to execute an effective response to an incident, and procedures to document, analyze, classify, and respond to incidents.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave conducts annual BCP/DR tests and documents according to the BCDR Plan.	Inspected the BCDR tabletop exercise meeting notes to determine that the company conducts annual BCP/DR tests and documents according to the BCDR Plan.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation	Nave has a defined backup policy that establishes the requirements for backup	Inspected the Backup Policy to determine that the company has a defined backup policy that establishes the requirements for backup data and systems.	No exceptions noted.

	activities for risks arising from potential business disruptions.	information, software and systems.		
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	Inspected the Incident Response Plan to determine that Nave documents a post-mortem review for identified incidents that includes root-cause analysis and lessons learned as applicable per company policies and procedures. The incident response plan is modified and evolved according to lessons learned and to incorporate industry developments.	No exceptions noted.
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Nave has identified an incident response team that quantifies and monitors incidents involving security, availability, processing integrity, and confidentiality at the company.	Inspected the key personnel info to determine that the company has designated a Security Officer, Privacy Officer, and Security Committee to manage incident response activities appropriately.	No exceptions noted.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.	Nave has a documented policy that outlines requirements for managing vendor and third party relationships.	Inspected the Vendor Management Policy to determine that the company has defined requirements including vendor risk assessment and review of the vendors to ensure that third-party entities meet the organization's data preservation and protection requirements.	No exceptions noted.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.	Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	Inspected Vendor Compliance Report to determine that Nave obtains and reviews compliance reports (e.g., SOC 2, ISO, PCI) or other evidence for critical vendors and service providers at least annually to monitor the third parties' compliance with industry frameworks, regulations, standards and Nave's requirements. Results of the review and action items, if any, are documented.	No exceptions noted.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.	Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant	Inspected Vendor Inventory to determine that Nave maintains a vendor/third party register that includes description for each of the services provided, risk ratings and tracking of vendor governance activities. Agreements with vendors and service providers involved in accessing, processing, storing or managing information assets are reviewed to validate they address all relevant requirements prior to execution.	No exceptions noted.

requirements prior to
execution.

